

CISSP Manager-Mindset Guide

DOMAIN 2 | ASSET SECURITY

Ownership • Classification • Handling • Lifecycle • Data protection

PURPOSE A decision-oriented guide to identifying what must be protected, who decides, how it should be handled, and when it may be retained or destroyed.

Aligned to the ISC2 CISSP Certification Exam Outline effective April 15, 2024
Domain weight: 10%

How to Use This Guide

Domain 2 questions are usually lifecycle and accountability questions disguised as technical questions. Before choosing encryption, DLP, destruction, or access controls, identify the asset, owner, classification, business purpose, legal obligations, data state, location, and point in the lifecycle.

DEFAULT DECISION LENS Inventory and classify first. Let the accountable owner determine value and handling needs. Apply protection throughout the lifecycle, collect and retain only what is justified, and verify secure disposition.

The Domain 2 Manager Mindset

- You cannot protect assets consistently until you know what exists, where it is, who owns it, and how important it is.
- Business or data owners make classification and risk decisions; custodians implement and operate controls.
- Protection follows the data across systems, locations, formats, backups, third parties, and lifecycle stages.
- Use the highest applicable handling requirement when data sets with different classifications are combined.
- Minimize collection and retention; unnecessary data creates unnecessary risk and cost.
- Legal holds and regulatory obligations override routine destruction schedules.
- End of support is a risk-management trigger, not merely an IT inconvenience.
- Sanitization must match media type, data sensitivity, reuse plans, and verification requirements.

Domain 2 Roadmap

Objective	Focus	Primary decision question
2.1	Identify and classify information and assets	What is it, how valuable or sensitive is it, and who decides?
2.2	Handling requirements	What rules apply whenever the asset is accessed, moved, shared, stored, or disposed?
2.3	Secure provisioning	How is the asset authorized, recorded, configured, assigned, and tracked?
2.4	Data lifecycle	How is data governed from collection through destruction, and which role is accountable?
2.5	Retention and EOL/EOS	How long should the asset or information remain, and what happens when support ends?
2.6	Controls and compliance	Which controls fit the data state, scope, standard, risk, and obligation?

2.1 Identify and Classify Information and Assets

Asset Identification and Inventory

Easy definition: Asset identification determines what needs protection; inventory records authoritative details such as owner, location, type, criticality, dependencies, status, and lifecycle stage.

When it matters: Risk assessment, vulnerability management, incident response, licensing, continuity, patching, cloud governance, and disposal.

THINK LIKE A MANAGER Establish an owned, maintained inventory before claiming control coverage; include tangible, intangible, cloud, virtual, data, software, services, and dependencies.

EXAM TRAPS

- Limiting “assets” to physical equipment.
- Treating a discovery scan as a complete inventory without ownership or business context.
- Counting assets without identifying criticality and dependencies.
- Ignoring ephemeral cloud resources, SaaS, code, models, credentials, certificates, and data flows.
- Assuming the CMDB is accurate without reconciliation and lifecycle processes.

QUICK DISTINCTION Discovery finds candidates; inventory is the governed record; asset management controls the asset throughout its lifecycle.

Information Classification

Easy definition: Classification assigns a protection level based on sensitivity, value, criticality, legal duties, and business impact if confidentiality, integrity, or availability is lost.

When it matters: Access, labeling, encryption, transmission, storage, retention, monitoring, incident severity, and destruction.

THINK LIKE A MANAGER Provide simple criteria and let the information owner classify; apply controls consistently and review classification as value and context change.

EXAM TRAPS

- Letting IT or the custodian unilaterally classify business data.
- Classifying solely by confidentiality while ignoring integrity and availability.
- Overclassifying everything, which raises cost and encourages workarounds.
- Underclassifying aggregated data whose combined value is greater.
- Assuming classification never changes.

QUICK DISTINCTION Classification states protection need; labeling communicates the classification; handling rules specify required behavior.

Government and Commercial Classification Models

Easy definition: Government schemes often focus on national-security harm and formal clearance; commercial schemes use organization-defined levels such as public, internal, confidential, and restricted.

When it matters: Selecting handling rules, answering classification scenarios, and distinguishing clearance from business authorization.

THINK LIKE A MANAGER Use the classification system applicable to the organization and jurisdiction; do not force government terminology onto a commercial environment.

EXAM TRAPS

- Assuming “confidential” has the same legal meaning in government and commercial schemes.
- Equating a security clearance with automatic access.
- Forgetting need-to-know even when clearance level is sufficient.
- Assuming public information needs no integrity or availability protection.

QUICK DISTINCTION Clearance is eligibility; classification is the information’s level; need-to-know and authorization determine actual access.

Classification Criteria

Criterion	Manager question	Possible consequence
Confidentiality	What happens if unauthorized people see it?	Privacy harm, fraud, competitive loss, legal exposure
Integrity	What happens if it is altered or becomes untrustworthy?	Unsafe decisions, incorrect transactions, regulatory failures
Availability	What happens if it is unavailable or delayed?	Operational outage, safety risk, revenue loss
Value/criticality	What business mission depends on it?	Recovery priority and investment requirements
Obligations	What law, contract, license, or policy applies?	Minimum handling, retention, reporting, or location duties
Aggregation	Does the combined set reveal more than each element?	Higher sensitivity and reclassification

2.2 Information and Asset Handling Requirements

Handling Rules

Easy definition: Handling requirements specify how assets may be created, labeled, accessed, copied, stored, transmitted, transported, shared, backed up, retained, and destroyed.

When it matters: Every lifecycle stage and every place people, systems, vendors, or media interact with an asset.

THINK LIKE A MANAGER Define mandatory handling requirements by classification and make them usable, enforceable, auditable, and consistent across physical and digital forms.

EXAM TRAPS

- Treating encryption as the complete handling standard.
- Protecting production copies but not exports, logs, caches, backups, or test data.
- Relying on labels without access enforcement and training.
- Allowing users to choose transfer methods based on convenience.
- Ignoring physical documents and removable media.

QUICK DISTINCTION Classification tells how sensitive or critical the asset is; handling requirements tell what people and systems must do because of that classification.

Marking and Labeling

Easy definition: Labels communicate classification, owner or origin, handling restrictions, and other required metadata to people and systems.

When it matters: Documents, emails, reports, removable media, backups, physical equipment, and automated policy enforcement.

THINK LIKE A MANAGER Use labels that drive clear action and automated enforcement where practical; protect label integrity and avoid exposing sensitive metadata unnecessarily.

EXAM TRAPS

- Assuming a visible label is itself an access control.
- Applying labels inconsistently across formats and copies.
- Allowing users to remove or downgrade labels without authorization.
- Placing revealing labels on the exterior of shipped media.
- Failing to update labels after approved reclassification.

QUICK DISTINCTION Labeling communicates; access control enforces; audit records demonstrate handling.

Data Aggregation and Inference

Easy definition: Aggregation risk occurs when combined data becomes more sensitive; inference occurs when someone derives sensitive facts from data that appears less sensitive.

When it matters: Data warehouses, analytics, AI, reports, metadata, anonymized sets, research, and access to multiple repositories.

THINK LIKE A MANAGER Evaluate the combined view and possible deductions—not only each field or source in isolation—and raise protection when aggregation increases harm.

EXAM TRAPS

- Assuming individually public or low-sensitivity records remain low risk when combined.
- Treating masking as permanent anonymization.
- Ignoring metadata and statistical reidentification.
- Giving broad analytics access because no single table contains restricted data.

QUICK DISTINCTION Aggregation increases value or sensitivity through combination; inference derives hidden information from available facts.

Handling by Lifecycle Action

Action	Key requirements	Exam cue
Access/use	Authorization, need-to-know, least privilege, logging	Who is permitted and for what purpose?
Copy/export	Owner approval, labeling, destination control, minimization	Does the copy inherit classification and retention?
Transmit	Approved channel, encryption/integrity, recipient validation	Protect data in transit and prevent misdelivery.
Store	Approved location, access, encryption, backup, residency	Know every location and provider.
Transport media	Inventory, tamper evidence, custody, encryption	Physical custody remains important.
Dispose	Authorization, legal check, method, verification, records	Destroy only when permitted and prove completion.

2.3 Provision Information and Assets Securely

Secure Asset Provisioning

Easy definition: Provisioning authorizes, records, configures, protects, assigns, and deploys an asset so it begins operation in a known, approved state.

When it matters: Endpoints, servers, network devices, cloud resources, software, service accounts, datasets, keys, and media.

THINK LIKE A MANAGER Require owner and purpose, record the asset, apply an approved baseline, assign accountability, validate controls, and obtain acceptance before production use.

EXAM TRAPS

- Deploying first and adding the asset to inventory later.
- Assuming vendor defaults are secure.
- Provisioning access without owner approval or role justification.
- Failing to record dependencies, data classification, support dates, or decommission plan.
- Confusing a successful installation with security acceptance.

QUICK DISTINCTION Provisioning creates and prepares; configuration management maintains the approved state; asset management governs the full lifecycle.

Asset Ownership and Custodianship

Easy definition: The owner is accountable for value, classification, access, retention, and risk decisions; the custodian implements and operates controls according to those decisions.

When it matters: Classification, access approval, exceptions, backup, patching, retention, disposal, and incident response.

THINK LIKE A MANAGER Assign a named, authoritative owner for each important asset or information set; do not let technical possession become accidental ownership.

EXAM TRAPS

- Having a system administrator accept business risk.
- Confusing the creator or user with the owner.
- Assigning an owner with no authority or knowledge of the business process.
- Leaving ownership undefined after reorganization or acquisition.
- Assuming cloud-provider custody transfers ownership.

QUICK DISTINCTION Owner decides and is accountable; custodian handles and protects; user accesses and follows rules.

Asset Inventory and Management

Easy definition: Asset management maintains accurate status, ownership, location, configuration relationships, support state, and disposition records from acquisition through retirement.

When it matters: Control coverage, audit, incident scoping, vulnerability prioritization, license management, continuity, and supply-chain risk.

THINK LIKE A MANAGER Tie technical discovery to business ownership and lifecycle workflows; reconcile inventory continuously rather than relying on periodic spreadsheets.

EXAM TRAPS

- Equating inventory with asset management.
- Ignoring unauthorized or shadow assets because they are not in the official record.
- Keeping retired assets active in monitoring and licensing records.
- Using one identifier that changes when location or hostname changes.
- Failing to inventory data and services separately from the devices hosting them.

QUICK DISTINCTION Inventory answers “what and where”; management adds ownership, lifecycle actions, control, and accountability.

Secure Provisioning Sequence

Order	Action	Why it comes here
1	Establish business purpose and accountable owner	No asset should exist without justified need and authority.
2	Identify classification, obligations, and risk	Requirements determine the baseline and controls.
3	Procure or create through approved process	Supply-chain and licensing risks begin before deployment.
4	Record in inventory and assign identifiers	Tracking starts before operational use.
5	Apply baseline, access, encryption, logging, and resilience	Controls implement the requirements.
6	Validate and authorize production use	Evidence and risk acceptance precede operation.
7	Monitor, maintain, and eventually decommission	Provisioning begins—not completes—the lifecycle.

2.4 Manage the Data Lifecycle

Data Lifecycle Governance

Easy definition: The data lifecycle governs information from planning and collection through use, sharing, storage, retention, archival, and destruction.

When it matters: Privacy, records management, cloud, analytics, backups, legal discovery, migrations, mergers, and decommissioning.

THINK LIKE A MANAGER Assign accountability and protection at every stage; data does not stop being governed when it is copied, archived, outsourced, or placed in backup.

EXAM TRAPS

- Focusing only on active production data.
- Assuming deletion from an application deletes replicas and backups.
- Applying one retention period to every record.
- Ignoring data created by logs, telemetry, analytics, and AI.
- Failing to update controls when purpose, classification, location, or ownership changes.

QUICK DISTINCTION Lifecycle governance controls why data exists, how it is used, where it goes, how long it remains, and how its end is verified.

Data Owner, Controller, Custodian, Processor, and Subject

Easy definition: The owner is accountable within the organization; a controller determines purposes and means of personal-data processing; a processor acts for the controller; a custodian operates controls; the subject is the person the data concerns.

When it matters: Privacy, cloud services, outsourcing, access approval, incident responsibility, contracts, and international processing.

THINK LIKE A MANAGER Map roles explicitly because obligations follow decision authority and processing relationships—not simply possession of the data.

EXAM TRAPS

- Assuming the cloud provider becomes the data owner.
- Confusing controller with custodian.
- Treating a processor as free to reuse personal data for its own purposes.
- Calling the data subject the owner in every legal context.
- Ignoring joint controllers and subprocessors.

QUICK DISTINCTION Controller determines why/how personal data is processed; processor acts on instructions; custodian operates safeguards; subject is the individual represented.

Data Collection and Minimization

Easy definition: Collection should be limited to information that is necessary, relevant, lawful, and proportionate to a defined business purpose.

When it matters: Forms, telemetry, identity proofing, logs, employee monitoring, customer analytics, AI training, and vendor integrations.

THINK LIKE A MANAGER Define purpose and authority before collection; gather the minimum needed and avoid speculative retention “just in case.”

EXAM TRAPS

- Collecting extra fields because storage is inexpensive.
- Assuming consent always makes excessive collection acceptable.
- Ignoring passive collection, metadata, cookies, and derived attributes.
- Using collected data later for an incompatible purpose without review.
- Failing to disable collection when the purpose ends.

QUICK DISTINCTION Data minimization reduces what is collected; purpose limitation restricts why it may be used; retention limitation controls how long it remains.

Data Location, Maintenance, and Quality

Easy definition: Organizations must know where authoritative and copied data resides and maintain accuracy, integrity, availability, and appropriate protection.

When it matters: Cloud regions, SaaS, endpoints, backups, third parties, data lakes, migrations, synchronization, and privacy rights.

THINK LIKE A MANAGER Maintain a data map and accountable source of truth; control copies, reconcile changes, validate quality, and assess every location and transfer path.

EXAM TRAPS

- Mapping only primary databases.
- Assuming cloud region selection controls all support and backup access.
- Correcting one record while leaving replicas inconsistent.
- Treating stale or inaccurate data as only a quality issue when it can cause security, safety, or privacy harm.
- Allowing uncontrolled local exports.

QUICK DISTINCTION Asset inventory tracks resources; data mapping traces information types, flows, stores, recipients, and jurisdictions.

Data Retention and Legal Hold

Easy definition: Retention keeps information for a justified period based on legal, contractual, operational, historical, and risk needs; a legal hold suspends routine destruction for relevant information.

When it matters: Records schedules, privacy, litigation, investigations, backups, archives, and disposal.

THINK LIKE A MANAGER Use approved schedules by record type, retain no longer than justified, and immediately preserve relevant information when a valid hold applies.

EXAM TRAPS

- Keeping everything forever to be safe.
- Destroying data according to schedule after a legal hold is issued.
- Assuming backups are exempt from retention and discovery.

- Letting individual users decide what constitutes an official record.
- Confusing retention duration with backup frequency.

QUICK DISTINCTION Retention schedule says when data should be kept or destroyed; legal hold temporarily overrides normal destruction for relevant evidence.

Data Remanence and Sanitization

Easy definition: Data remanence is recoverable information left after ordinary deletion; sanitization reduces recovery risk using clearing, purging, or destruction appropriate to the media and reuse plan.

When it matters: Disk reuse, device return, cloud storage, removable media, printers, mobile devices, failed equipment, and disposal.

THINK LIKE A MANAGER Select the sanitization method from sensitivity, media behavior, destination, and assurance needs; verify and document completion before release.

EXAM TRAPS

- Assuming file deletion or formatting removes the data.
- Using degaussing on media it does not affect, such as optical discs or many solid-state devices.
- Reusing damaged media that cannot be reliably sanitized.
- Forgetting encryption keys, snapshots, spare sectors, caches, and provider replicas.
- Destroying media unnecessarily when verified purge is sufficient and reuse is valuable.

QUICK DISTINCTION Clear protects against simple recovery and often permits internal reuse; purge resists advanced recovery and may permit broader reuse; destroy makes media unusable.

Data Roles Comparison

Role	Primary responsibility	Exam trap
Owner	Classifies, approves access/retention, accepts risk	Usually a business role—not the administrator.
Controller	Determines purposes and means of personal-data processing	May use processors but retains controller obligations.
Custodian	Implements storage, backup, access, and handling controls	Does not normally decide classification or accept business risk.
Processor	Processes personal data for a controller under instructions	Subprocessors and reuse require governance.
User	Uses data for authorized purposes and follows policy	Access does not confer ownership.
Subject	Individual whom personal data concerns	Has applicable rights; not necessarily organizational owner.

2.5 Retention, End of Life, and End of Support

Retention Requirements

Easy definition: Asset and information retention balances business value and recovery needs against legal duties, privacy, storage cost, security exposure, and discovery risk.

When it matters: Records, logs, backups, evidence, financial data, HR data, configuration history, cryptographic material, and retired systems.

THINK LIKE A MANAGER Create defensible schedules by information type, owner, obligation, and purpose; automate disposition where practical and retain evidence of authorized destruction.

EXAM TRAPS

- Using storage capacity as the primary reason to retain.
- Keeping logs forever without a defined use or protection plan.
- Deleting too early to meet legal, operational, audit, or recovery needs.
- Applying the production retention period blindly to backups.
- Failing to account for suspended destruction during investigations.

QUICK DISTINCTION Backup supports recovery; archive supports long-term reference or records needs. Neither should become unmanaged permanent storage.

End of Life vs. End of Support

Easy definition: End of life means the product is being retired from its lifecycle; end of support means the supplier no longer provides some or all updates, fixes, or assistance. Dates and definitions vary by vendor.

When it matters: Technology roadmaps, vulnerability management, procurement, exceptions, legacy systems, OT, medical devices, and contracts.

THINK LIKE A MANAGER Track support milestones early, assess business and security impact, migrate when feasible, and formally approve time-bounded compensating controls when replacement is constrained.

EXAM TRAPS

- Treating EOL and EOS as universally identical.
- Waiting until support ends to plan migration.
- Assuming isolation makes unsupported technology safe.
- Patching an unsupported system from untrusted sources.
- Accepting a permanent exception without owner, monitoring, exit plan, or review.

QUICK DISTINCTION EOL is a lifecycle status; EOS is the loss of vendor support. Either can trigger elevated risk, but the practical impact depends on the product and environment.

Legacy Assets and Compensating Controls

Easy definition: When an asset cannot be replaced promptly, compensating controls provide alternative risk reduction while the organization works toward an approved target state.

When it matters: OT, healthcare, embedded systems, proprietary platforms, expired software, and fragile business dependencies.

THINK LIKE A MANAGER Document why replacement is constrained, reduce exposure in layers, monitor aggressively, obtain owner acceptance, and maintain a funded exit plan.

EXAM TRAPS

- Calling any workaround a compensating control.
- Using network isolation as the only control.
- Leaving the exception open-ended.
- Ignoring recovery, spare parts, vendor access, and configuration knowledge.
- Treating business criticality as a reason not to address risk.

QUICK DISTINCTION A compensating control must address the original objective with comparable risk reduction; an exception merely documents approved deviation and residual risk.

2.6 Data Security Controls and Compliance

Data States: At Rest, In Transit, and In Use

Easy definition: Data at rest is stored, data in transit moves across a communication path, and data in use is actively processed in memory or by an application.

When it matters: Selecting encryption, access, integrity, monitoring, isolation, and privacy controls.

THINK LIKE A MANAGER Map data flows and apply controls to every state and transition; protection at rest does not automatically protect data after decryption or transfer.

EXAM TRAPS

- Assuming full-disk encryption protects data from an authorized logged-in user or compromised application.
- Encrypting the network but exposing data at endpoints.
- Ignoring temporary files, memory, caches, and processing services.
- Treating backups as a different state from stored data.
- Choosing controls without key and identity management.

QUICK DISTINCTION At rest = stored. In transit = moving. In use = actively processed, usually requiring access control, isolation, trusted execution, or application-level protections.

Scoping and Tailoring Controls

Easy definition: Scoping determines which systems, data, people, locations, and processes are included; tailoring adjusts a baseline to the environment and documented risk while preserving required objectives.

When it matters: Framework adoption, compliance, cloud boundaries, segmentation, compensating controls, inherited controls, and audits.

THINK LIKE A MANAGER Define the boundary from business processes and data flows, then tailor with documented rationale, ownership, and residual-risk approval.

EXAM TRAPS

- Reducing scope on paper while data or connectivity remains in scope.
- Removing a control because it is inconvenient without addressing the objective.
- Assuming segmentation automatically proves systems are out of scope.
- Ignoring shared services and administrative paths.
- Treating inherited controls as someone else's accountability.

QUICK DISTINCTION Scoping defines where requirements apply; tailoring adjusts how the requirements are met within that scope.

Standards Selection

Easy definition: Standards should be selected based on applicable law, contracts, industry, information type, customer commitments, risk, and organizational objectives.

When it matters: Control baselines, audits, cloud, payment data, health information, government work, and international operations.

THINK LIKE A MANAGER Identify mandatory requirements first, then use suitable standards to create a coherent control system and map overlaps rather than operating disconnected checklists.

EXAM TRAPS

- Selecting the most familiar standard without checking applicability.
- Assuming certification to one standard satisfies every obligation.
- Implementing every control without scope and context.
- Building separate duplicate controls for each framework.
- Confusing a control framework with a law.

QUICK DISTINCTION Requirements state obligations; standards provide structured expectations; controls are the safeguards implemented to meet objectives.

Data Loss Prevention (DLP)

Easy definition: DLP identifies and controls sensitive data movement or use based on content, context, identity, destination, and policy across endpoints, networks, email, and cloud services.

When it matters: Preventing accidental or unauthorized disclosure, enforcing handling rules, monitoring exfiltration, and coaching users.

THINK LIKE A MANAGER Start with classification, data flows, use cases, and ownership; tune policy carefully and provide an exception and incident process.

EXAM TRAPS

- Deploying DLP before knowing what sensitive data looks like.
- Blocking every match without considering business processes and false positives.
- Treating DLP as a replacement for access control, training, or data minimization.
- Ignoring encrypted channels, screenshots, photography, and sanctioned cloud applications.
- Monitoring employees without legal, privacy, and policy review.

QUICK DISTINCTION DLP detects or controls data movement and use; DRM persists usage restrictions with the content itself.

Digital Rights Management (DRM)

Easy definition: DRM applies persistent controls to content, such as who may open, copy, print, forward, modify, or use it and for how long.

When it matters: Sensitive documents, intellectual property, licensed media, external sharing, and post-delivery control.

THINK LIKE A MANAGER Use DRM when restrictions must travel with content, but plan identity, availability, recovery, and authorized exceptions.

EXAM TRAPS

- Assuming DRM prevents every screenshot or analog copy.
- Ignoring availability if the authorization service fails.
- Applying restrictions that prevent legitimate recovery, discovery, or business use.
- Treating DRM as encryption-only.

- Failing to revoke rights when roles or contracts change.

QUICK DISTINCTION Encryption protects content from unauthorized reading; DRM also governs permitted actions after authorized access.

Cloud Access Security Broker (CASB)

Easy definition: A CASB provides visibility and policy enforcement between cloud users and cloud services, often supporting discovery, DLP, access control, threat detection, and compliance.

When it matters: SaaS usage, shadow IT, cloud data movement, unmanaged devices, and policy consistency across providers.

THINK LIKE A MANAGER Use CASB capabilities to enforce a defined cloud governance and data strategy; do not expect a broker to compensate for unclear ownership or classification.

EXAM TRAPS

- Treating CASB as a complete cloud-security program.
- Ignoring traffic or APIs outside the deployment mode's visibility.
- Assuming every CASB provides identical inline and API capabilities.
- Blocking unsanctioned services without a usable approved alternative.
- Overlooking provider-native controls and shared responsibility.

QUICK DISTINCTION CASB governs access and data interaction with cloud services; CSPM focuses on cloud configuration posture; CWPP protects workloads.

Control Selection by Data State

State	Primary risks	Illustrative controls
At rest	Theft, unauthorized access, remanence, loss	Encryption, access control, key management, backup, sanitization
In transit	Interception, alteration, misdelivery, replay	TLS/IPsec, integrity/authentication, recipient validation, secure transfer
In use	Excess privilege, process compromise, leakage, memory exposure	Least privilege, isolation, application controls, masking, trusted execution
Across states	Uncontrolled copies, shadow services, policy inconsistency	Classification, DLP, DRM, CASB, logging, data mapping

Cross-Domain Exam Traps for Domain 2

Who Decides and Who Acts?

Decision or action	Likely role	Trap to avoid
Classify information	Information/data owner	Custodian should advise and implement—not own the business decision.
Approve access	Owner or delegated authority	Administrator provision does not equal approval.
Set retention schedule	Records/legal/privacy plus owner	Storage team should not decide based on capacity.
Operate backups and access controls	Custodian/operations	Operation does not transfer risk ownership.
Determine processing purposes	Controller	Processor follows documented instructions.
Accept residual risk	Authorized risk owner	Auditor, user, or vendor should not accept for the business.
Place legal hold	Authorized legal process/counsel	Routine destruction must stop for relevant information.

What Happens First?

- Unknown assets or uncontrolled data: inventory and identify ownership before selecting broad controls.
- New information type: define business purpose, owner, classification, obligations, and handling requirements.
- Control selection: map data flows, states, locations, users, threats, and required outcomes first.
- Disposal: confirm authorization, retention schedule, legal holds, classification, media type, and destination before sanitizing.
- Unsupported system: assess business need and risk, identify feasible migration, then approve interim compensating controls.
- Cloud service: determine data, purpose, roles, location, provider responsibilities, exit requirements, and risk before use.
- Possible overcollection: validate necessity and authority before finding a larger or more secure place to store it.

ROOT-CAUSE TRAP If sensitive information is leaking, a DLP purchase may be attractive. The better first answer may be to identify and classify the data, determine legitimate flows, establish handling policy, and assign ownership so DLP rules can be accurate and enforceable.

Domain 2 Rapid Review

ONE-SENTENCE DOMAIN SUMMARY Know what the organization has, assign an accountable owner, classify it by business impact and obligation, enforce handling throughout its lifecycle, retain only as justified, and verify secure disposition.

High-Yield Distinctions

Concept A	Concept B	Fast distinction
Asset discovery	Asset inventory	Finds candidates vs. governed authoritative record
Inventory	Asset management	Record of assets vs. lifecycle governance and action
Owner	Custodian	Decides and is accountable vs. implements and operates
Controller	Processor	Determines why/how personal data is processed vs. acts on instructions
Classification	Labeling	Assigns protection level vs. communicates it
Data minimization	Retention limitation	Collect less vs. keep for less time
Backup	Archive	Operational recovery vs. long-term reference/record purpose
Clear	Purge	Defeats simple recovery vs. resists advanced recovery
EOL	EOS	Lifecycle retirement vs. loss of vendor support
Scoping	Tailoring	Defines applicability boundary vs. adjusts baseline implementation
DLP	DRM	Controls movement/use through inspection vs. persistent content rights
Encryption	Sanitization	Protects with a key vs. renders recovery infeasible

Final Manager-Mindset Checklist

- What is the asset or information, and does the inventory accurately reflect it?
- Who is the accountable owner—not merely the technical custodian?
- How would loss of confidentiality, integrity, or availability affect the business?
- What laws, contracts, standards, privacy duties, or legal holds apply?
- Where is the data, where does it flow, and which third parties receive or process it?
- What classification and handling rules apply to copies, exports, backups, logs, and aggregates?
- Is collection and retention necessary and proportionate?
- Are controls appropriate for data at rest, in transit, and in use?
- Can disposition be authorized, verified, documented, and applied to all copies?
- What residual risk remains, and has the proper owner accepted it?

Source and Scope Note

Coverage is aligned to the ISC2 CISSP Certification Exam Outline effective April 15, 2024. This independent study aid uses original explanations and does not reproduce exam questions or official courseware. Official outline: <https://www.isc2.org/certifications/cissp/cissp-certification-exam-outline>